

ACCEPTABLE USE & BYOD POLICY

Tumaini Capital Ltd | ISMS-POL-004 | ISO/IEC 27001:2022 — Annex A 5.10, 6.7, 8.1 | Fictional case study

Document Title	Acceptable Use & BYOD Policy	Document ID	ISMS-POL-004
Version	1.0	Status	<i>DRAFT — Pending Approval</i>
Author	Head of Risk & Compliance (ISMS Lead)	Date	June 2026
Approved By	ISMS Lead & CEO	Next Review	June 2027
Related Documents	ISMS-POL-001 (Information Security Policy), ISMS-POL-002 (Access Control Policy), ISMS-POL-005 (Information Classification Policy)		

1. PURPOSE AND SCOPE

This policy defines the acceptable use of Tumaini Capital's information systems, devices, and data by all staff, contractors, and third parties. It also sets the minimum-security requirements for personally-owned (BYOD) devices used to access company information or systems.

This policy applies to all Tumaini Capital staff and contractors at both the Nairobi and Kisumu offices, and to all personally-owned devices used for any business purpose including accessing email, Google Workspace, WhatsApp Business, or the CRM system.

2. GENERAL PRINCIPLES

Tumaini Capital's information systems and devices are provided to support legitimate business activities. Use of these systems is a privilege, not a right, and is subject to the terms of this policy. The following principles apply at all times:

- Company information systems shall be used primarily for business purposes. Incidental personal use is permitted provided it does not conflict with business needs, consume significant resources, or create a security risk.
- Every user is personally accountable for all activity conducted under their credentials. Accounts and passwords must never be shared.
- Users shall treat company information, systems, and devices with the same care they would apply to any other company asset.
- This policy applies equally on company premises and when working remotely.

3. EMAIL AND COMMUNICATIONS TOOLS

3.1 Email

- The company's Google Workspace email system is the primary channel for formal business communications.
- Confidential or Restricted information (as defined in the Information Classification Policy, ISMS-POL-005) must not be sent via personal email accounts.
- Staff must not open email attachments or click links from unknown or unexpected senders without first verifying the source. Suspected phishing emails must be reported immediately.
- Mass email to customer lists must be approved by the Head of Operations.

3.2 WhatsApp Business

WhatsApp Business is approved for customer-facing communications and internal coordination. The following restrictions apply:

- KYC documents (copies of national IDs, bank statements, payslips) must never be shared via WhatsApp under any circumstances. Use the approved secure document portal or email with encryption.
- Customer loan decisions, credit scores, and financial data must not be transmitted via WhatsApp.
- Staff must use the company-managed WhatsApp Business account for customer communications, not personal WhatsApp numbers.
- WhatsApp conversations relating to customer accounts may be subject to review as part of an incident investigation.

4. INTERNET ACCESS

- Internet access is provided for business purposes. Accessing websites for legitimate personal use during breaks is acceptable provided bandwidth use is reasonable.
- Accessing websites that host illegal content, promote extremism, contain adult content, or are known to distribute malware is strictly prohibited.
- Downloading software, browser extensions, or executable files from the internet onto company devices requires prior approval from the Head of Engineering.
- Use of anonymizing tools (VPNs not provided by Tumaini Capital, Tor, proxy services) on company devices is not permitted without ISMS Lead approval.

5. SOCIAL MEDIA

- Staff must not post, share, or comment on social media in a way that could be attributed to Tumaini Capital without prior approval from the CEO or Head of Operations.
- No customer data, borrower information, KYC documents, financial data, or internal business information may be shared on any social media platform.
- Staff must not discuss ongoing security incidents, regulatory investigations, or legal matters on social media.
- Personal social media use during working hours should be limited to break times and must not be conducted on company systems.

6. BYOD — REQUIREMENTS FOR PERSONAL DEVICES

Tumaini Capital permits staff to use personally-owned smartphones to access company email, Google Workspace, and WhatsApp Business for business purposes. The following minimum-security requirements apply to any personal device used for business:

- Screen lock must be enabled with a minimum 6-digit PIN, pattern, or biometric, activating within 5 minutes of inactivity.
- Full-disk encryption must be enabled where the device supports it (this is enabled by default on all modern Android and iOS devices).
- The device must be running a supported operating system with current security updates applied.
- The device must have reputable anti-malware software installed (Android devices) or rely on iOS/iPadOS built-in security (iOS/iPadOS devices).
- Company email and applications must be accessed through approved apps (Google Gmail, Google Drive, WhatsApp Business) rather than via personal browsers where possible.

By using a personal device to access Tumaini Capital's systems, the device owner consents to the company remotely revoking access to company data and applications in the event of device loss, theft, or employment termination. This action is limited to company data and applications; personal data stored on the device will not be affected.

7. DATA HANDLING ON PERSONAL DEVICES

- Customer KYC documents, loan records, and financial data must not be permanently stored on personal devices. Temporary viewing for operational purposes is permitted; downloaded files must be deleted immediately after use.
- Company data must be stored in approved company systems (Google Workspace, CRM, AWS). Personal cloud storage accounts (iCloud, personal Google Drive, Dropbox) must not be used for company data.
- Personal devices used for business must be reported as lost or stolen to the ISMS Lead immediately upon discovery. Remote wipe of company data may be initiated without delay.

8. REMOTE WORKING

- Staff working remotely must connect to in-scope systems (CRM, AWS) via multi-factor authentication.
- Video calls and voice calls relating to sensitive matters should be conducted in a private location where the conversation cannot be overheard.
- Screens displaying confidential or restricted information must not be visible to household members or members of the public.
- Public Wi-Fi networks (cafes, airports, hotels) must not be used to access company systems unless a company-approved VPN is active.

9. SOFTWARE AND APPLICATIONS

- Staff must not install unapproved software or applications on company-issued devices without prior approval from the Head of Engineering.
- An approved software list is maintained by the Head of Engineering. Staff with a business need for software not on the approved list should submit a request for review.
- Browser extensions and plugins on company devices require approval before installation.

10. MONITORING

Tumaini Capital reserves the right to monitor activity on company-owned systems and devices, and on personal devices accessing company systems, to the extent necessary to ensure compliance with this policy, investigate security incidents, and meet legal obligations. Monitoring activity will be conducted in accordance with applicable Kenyan law and the Data Protection Act, 2019.

Monitoring is not intended as a surveillance mechanism for staff performance and will only be reviewed in the context of a suspected security incident or investigation.

11. REPORTING SECURITY CONCERNS

Staff who observe a potential violation of this policy or suspect their device or credentials have been compromised must report it immediately to the ISMS Lead via the security incident reporting channel. There will be no adverse consequences for good-faith reports.

12. CONSEQUENCES OF VIOLATION

Violations of this policy will be treated as a conduct matter and may result in disciplinary action up to and including termination of employment or contract. Violations involving the unauthorized disclosure of customer data may be reported to the ODPC as required under the Data Protection Act, 2019.

13. POLICY REVIEW

This policy shall be reviewed annually, following a significant security incident related to device or communications security, or following a material change to the approved tools and platforms in use.

Role	Name & Signature	Date
Head of Risk & Compliance / ISMS Lead		
Chief Executive Officer (Approver)		